

2026 年 4 月 18 日架构师网络课堂备忘录

一、本次课内容回顾

【课程主题】

1. 信息安全基础知识 3

【重点内容】

1.网络安全攻击

◆ 被动攻击类型

被动攻击：**收集信息为主**，破坏保密性。

主动攻击：主动攻击的类别主要有：中断（破坏可用性），篡改（破坏完整性），伪造（破坏真实性）。

攻击类型	攻击名称	描述
被动攻击	窃听（网络监听）	用各种可能的合法或非法的手段窃取系统中的 信息资源和敏感信息 。例如对通信线路中传输的信号进行搭线监听，或者利用通信设备在工作过程中产生的电磁泄漏截取有用信息等。
	业务流分析（截取）	通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等参数进行研究，从而发现有价值的信息和规律。
	非法登录	非法登录是指未经授权的人或者程序通过破解、盗用账号密码的方式，进入到平台的后台管理系统，进行非法操作或者窃取数据这些行为。有些资料将这种方式归为被动攻击方式。

◆ 主动攻击类型

攻击类型	攻击名称	描述
主动攻击	假冒身份	非法用户冒充成为合法用户，特权小的用户冒充成为特权大的用户。
	抵赖	这是一种来自用户的攻击，例如，否认自己曾经发布过的某条消息、伪造一份对方来信等。
	旁路控制【旁路攻击】	攻击者利用系统的安全缺陷或安全性上的脆弱之处获得非授权的权利或特权。例如，攻击者通过各种攻击手段发现原本应保密，但是却又暴露出来的一些系统特性，利用这些“特性”，攻击者可以绕过防线守卫者侵入系统的内部。
	重放攻击	所截获的某次合法的通信数据拷贝，出于非法的目的而被重新发送。 加【时间戳】能识别并应对重放攻击。
	拒绝服务（DOS）	破坏服务的【可用性】 ，对信息或其他资源的合法访问被无条件的阻止。

◆ 主动攻击类型（续）

WEB服务攻击	描述
XSS跨站脚本攻击	通过利用网页【 开发时留下的漏洞 】，通过巧妙的方法注入恶意指令代码到网页。
CSRF跨站请求伪造攻击	攻击者通过一些技术手段欺骗用户的浏览器与访问一个自己曾经认证过的网站并执行一些操作（如转账或购买商品等）。
缓冲区溢出攻击	利用【 缓冲区溢出漏洞 】所进行的攻击。在各种操作系统、应用软件中广泛存在。
SQL注入攻击	攻击者把SQL命令插入到Web表单，欺骗服务器执行恶意的SQL命令。 SQL注入攻击的方式 ：【恶意拼接查询】、【利用注释执行非法命令】、【传入非法参数】、【添加额外条件】。 抵御SQL攻击的方式 包括：【使用正则表达式】、【使用参数化的过滤性语句】、【检查用户输入的合法性】、【用户相关数据加密处理】、【存储过程来执行查询】、【使用专业的漏洞扫描工具】。

◆ 主动攻击类型（续）

其他安全威胁	描述
特洛伊木马	软件中含有一个察觉不出的或者无害的程序段，当它被执行时，会破坏用户的安全。这种应用程序称为特洛伊木马（Trojan Horse）
陷阱门	在某个系统或某个部件中设置了“机关”，使得当提供特定的输入数据时允许违反安全策略。
计算机病毒	所谓计算机病毒，是一种在计算机系统运行过程中能够实现传染和侵害的功能程序。一种病毒通常含有两个功能：一种功能是对其他程序产生“感染”；另外一种或者是引发损坏功能或者是一种植入攻击的能力。

2. 安全模型



安全模型

◆ 安全模型的分类

安全策略定义系统的抽象安全目标（要做什么）。安全模型提供形式化描述与实践指导（如何做），将策略转化为具体规则，是本图分类的基础。

基本模型：HRU（访问控制矩阵模型）

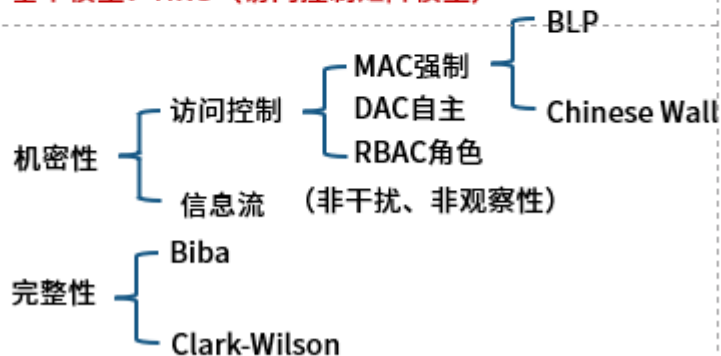
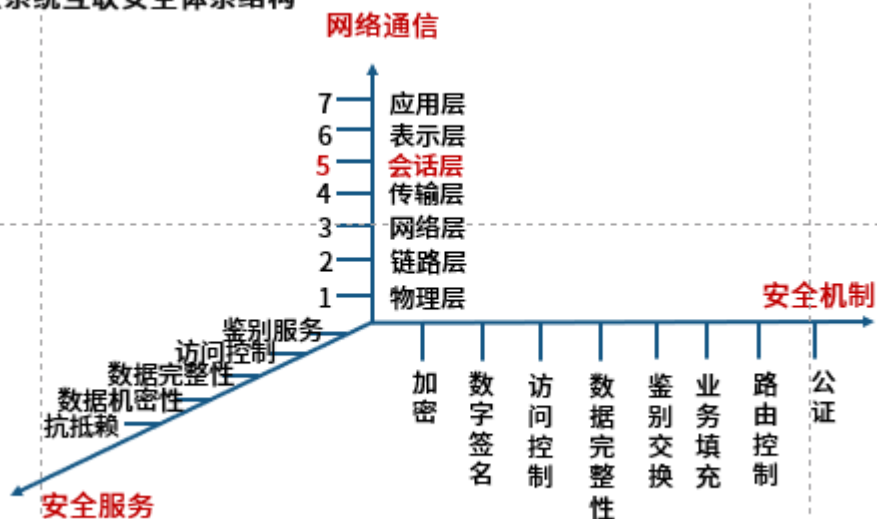


图 安全模型分类方法

3. 网络安全体系架构

◆ 开放系统互联安全体系结构



◆ 访问控制类型

控制类型	说明
基于对象的访问控制	OBAC访问控制系统是从 信息系统的 数据差异变化和 用户需求 出发，有效地解决了信息数据量大、数据种类繁多、数据更新变化频繁的大型管理信息系统的 安全管理 。 控制策略 和 控制规则 是OBAC访问控制系统的核心所在。
基于角色的访问控制	RBAC就是指根据 完成某些职责任务所需要的访问权限 来进行授权和管理。RBAC由 用户 （U）、 角色 （R）、 会话 （S）和 权限 （P）四个基本要素组成。
基于任务的访问控制	TBAC是从应用和企业层角度来解决安全问题，以面向任务的观点，从任务（活动）的角度来建立安全模型和实现安全机制，在任务处理的过程中提供动态实时的安全管理。 TBAC模型由 工作流 、 授权结构体 、 受托人集 和 许可集 四部分组成。其一般用五元组（S，O，P，L，AS）来表示，其中S表示主体，O表示客体，P表示许可，L表示生命期，AS表示授权步。
基于属性的访问控制	ABAC是根据主体的属性、客体的属性、环境的条件以及访问策略对主体的请求操作进行授权许可或拒绝。

4.区块链

◆ 区块链的定义

➤ 狭义定义

区块链技术是一种按照时间顺序将数据区块以顺序相连的方式组合成链式数据结构，并以密码学方式保证不可篡改和不可伪造的分布式账本技术。

➤ 广义定义

区块链技术是利用**块链式数据结构**来验证与存储数据、利用**分布式节点共识算法**来生成和更新数据、利用**密码学方式**保证数据传输和访问的安全、利用由自动化脚本代码组成的**智能合约**来编程和操作数据的一种全新的分布式基础架构与计算范式。

◆ 区块链基础架构的六层模型



◆ 区块链的特点

- (1) 去中心化（无中心机构，节点共同维护）
- (2) 开放性（交易数据公开，身份信息强加密）
- (3) 自治性（规则由代码自动执行，无需人为操作）
- (4) 安全性（数据分布式存储，需攻破超半数节点）
- (5) 匿名性（交易通过密钥验证，无需公开身份）

◆ 区块链的四大基础技术支柱

1. **分布式账本**（数据不存放在单一服务器，而是分散存储在全球数千个节点上）

2. 密码学

- 哈希函数：将任意数据转换为固定长度字符串（如SHA-256算法）。
- 非对称加密（公私钥签名）：公钥加密（公开地址），私钥解密（仅所有者能操作资产）。

3. **共识机制**（让分散节点对新区块达成一致）。

- PoW（工作量证明）：比特币采用，节点通过算力竞赛获得记账权（“挖矿”）。
- PoS（权益证明）：以太坊采用，持币越多越有机会记账。

4. **智能合约**（自动执行，代码即法律。去中介化不可逆协议）

◆ 区块链的关键支撑技术

1. 区块结构 (Block Structure)

区块链中存储批量交易数据及验证信息的基本数据单元，由区块头和区块体组成，通过密码学方法链接形成不可篡改的链式结构。

2. P2P网络 (Peer-to-Peer Network)

一种去中心化的网络架构，其中所有节点 (Peer) 以平等地位互联，每个节点既能作为客户端请求服务，也能作为服务器提供资源或服务，不依赖中央服务器进行协调。

3. 默克尔树 (Merkle Tree)

一种基于密码学哈希函数构建的树形数据结构，通过逐层聚合子节点的哈希值，最终生成一个唯一的根哈希 (Merkle Root)，用于高效验证大规模数据的完整性。

二、下次课程安排

时间：2026 年 4 月 27 日 (星期一) 19: 30 - 21: 30

主题：论文写作 (实战篇 4)

另外请预习下下节课的内容

预习视频：新版系统架构设计师精讲视频教程

(视频学习的内容大致如下：

- (1) 进入我的“学习中心”
- (2) 选择“视频课程”
- (3) 选择“【2026 版本】系统架构设计师精讲视频教程”
- (4) 选择“论文写作【技巧篇】”章节的视频学习

)

三、课程回看

希赛网目前提供了两种课程回看的方式：

方式一：课程回放

优点：即时性强，课程结束后 20 分钟内可立即回看

缺点：未按章节分类，一次课的全部内容为一个视频

APP 观看路径：我的->网络课堂

PC 观看路径：学习中心->网络课堂

回看注意事项：

- (1) 首先登录希赛网(www.educity.cn), 然后使用以上地址回看。
- (2) 回看时如果需要拖放观看,有两种方法进行视频内容定位:方法一是将鼠标移至视频头像位置进行拖放;方法二是直接点击播放界面下方的微缩图,可直接定位到这一页 PPT 的讲解。

方式二：老师端录屏回看

优点：按章节进行划分，结构清晰。

缺点：需要人工做视频处理与发布，上完课后 1-2 个工作日发布。

APP 观看路径：我的->视频课程

PC 观看路径：学习中心->视频课程

四、课后习题

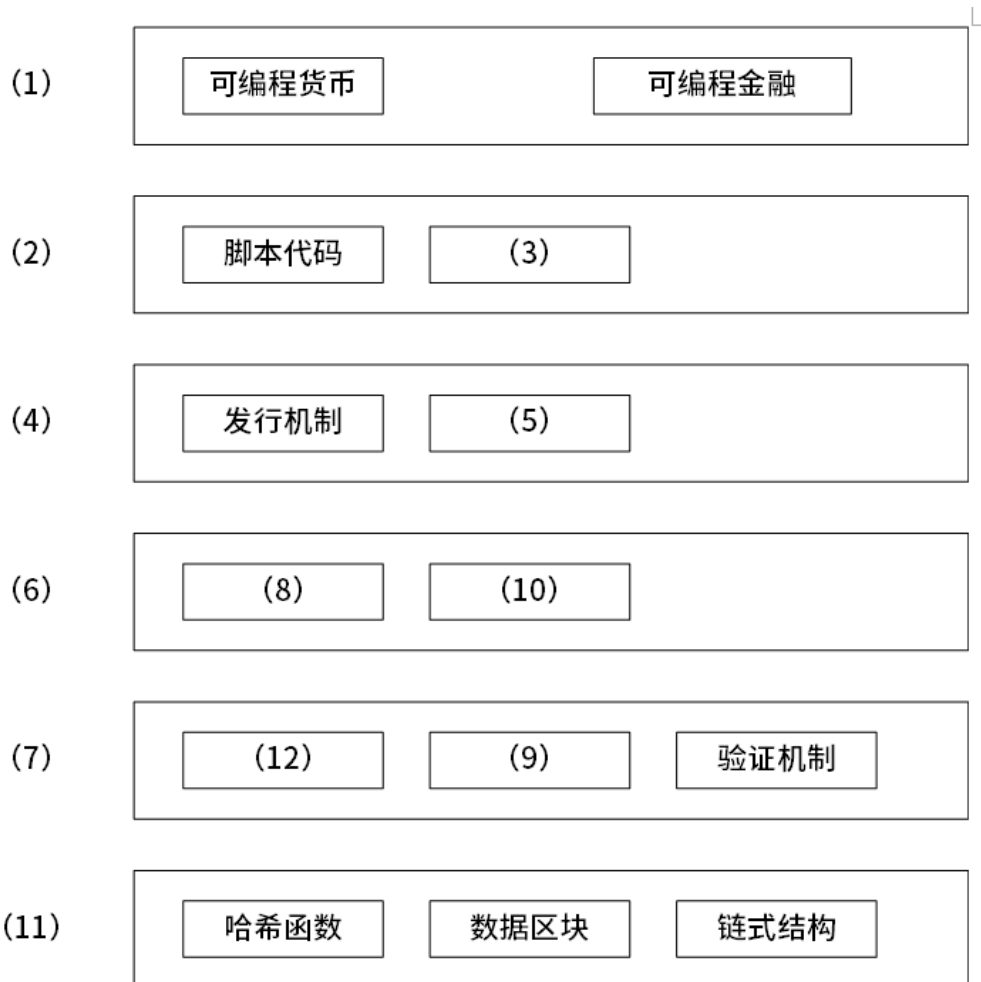
1. 下面攻击与抗攻击技术对应不正确的是 ()。
 - A.ARP 欺骗--采用双向绑定的方法解决并且防止 ARP 欺骗
 - B.传统拒绝服务--设置防火墙监视本地主机端口的使用情况
 - C.DNS 欺骗--交叉检查查询
 - D.分布式拒绝服务--通过设置防火墙过滤来自外部而信源地址却是内部 IP 的报文
2. 网络与信息安全风险中人为蓄意破坏分为被动型攻击和主动型攻击两种，以下属于被动攻击的是 ()。
 - A.网络监听
 - B.旁路攻击
 - C.抵赖
 - D.假冒身份
3. 下列攻击方式中，重放攻击属于 () 方式。
 - A.被动攻击
 - B.主动攻击
 - C.物理攻击
 - D.分发攻击
4. 【说明】

某金融机构计划构建基于区块链的跨境支付结算系统，旨在解决传统 SWIFT 体系手续费高、结算周期长

(通常 3-5 天)、中间行依赖性强等问题。该系统采用联盟链架构，由全球合作银行共同维护节点，通过智能合约自动完成外汇兑换与资金清算，目标实现分钟级到账且手续费降低 60%。

【问题 1】(12 分)

区块链是一种块链式存储、不可篡改、安全可信的去中心化分布式账本，它结合了分布式存储、点对点传输、共识机制、密码学等技术，通过不断增长的数据块链记录交易和信息，确保数据的安全和透明性。下图是区块链基础架构的六层模型。



请从以下 (a) ~ (n) 中选择合适的选项填入上图的 (1) ~ (12) 空中。

- (a) 数据层
- (b) 共识层
- (c) 激励层
- (d) 合约层
- (e) 应用层
- (f) 网络层
- (g) 接口层

- (h) 代码层
- (i) PoW
- (j) 智能合约
- (k) PBFT
- (l) 传播机制
- (m) 分配机制
- (n) P2P 网络

【问题 2】（9 分）

区块链的共识机制是保障分布式一致性的核心，跨境支付结算系统需使用 PBFT（实用拜占庭容错）共识机制。请用 200 字以内说明联盟链中常用的 PBFT（实用拜占庭容错）共识机制的工作原理，并对比其与公有链 PoW 机制在性能、能耗、适用场景三方面的差异。

【问题 3】（4 分）

系统需设计用户身份认证模块。请用 200 字以内说明如何结合数字证书与零知识证明技术，实现既符合 KYC 要求又保护用户隐私的身份验证方案。

【参考答案】

1.D

拒绝服务攻击与防御：

攻击		抗攻击技术
拒绝服务	传统拒绝服务	加强对数据包的特征识别
	分布式拒绝服务	设置防火墙监视本地主机端口的使用情况 对通信数据量进行统计也可获得有关攻击系统的位置和数量信息 尽可能的修正已经发现的问题和系统漏洞

欺骗攻击与防御：

攻击		抗攻击技术
欺骗攻击	ARP 欺骗	固化 ARP 表，阻止 ARP 欺骗 使用 ARP 服务器。 采用双向绑定的方法解决并且防止 ARP 欺骗。 ARP 防护软件——ARP Guard
	DNS 欺骗	被动监听检测 虚假保温探测 交叉检查查询
	IP 欺骗	预防这种攻击可以删除 UNIX 中所有的/etc/hosts.equiv、\$HOME/.rhosts 文件，修改/etc/inetd.conf 文件，使得 RPC 机制无法应用。 通过设置防火墙过滤来自外部而信源地址却是内部 IP 的报文。

2.A

被动攻击：收集信息为主，破坏保密性。

主动攻击：主动攻击的类别主要有：中断（破坏可用性），篡改（破坏完整性），伪造（破坏真实性）。

窃听（网络监听）：用各种可能的合法或非法的手段窃取系统中的信息资源和敏感信息。【被动攻击】

旁路控制（旁路攻击）：密码学中是指绕过对加密算法的繁琐分析，利用密码算法的硬件实现的运算中泄露的信息。如执行时间、功耗、电磁辐射等，结合统计理论快速的破解密码系统。【主动攻击】

抵赖：否认自己曾经发布过的某条消息、伪造一份对方来信等。【主动攻击】

假冒身份：非法用户冒充成合法用户，特权小的用户冒充成为特权大的用户。【主动攻击】

3.B

在被动攻击（passive attack）中，攻击者的目的只是获取信息，这就意味着攻击者不会篡改信息或危害系统。系统可以不中断其正常运行。常见的被动攻击包括：窃听和流量分析。

主动攻击（active attack）可能改变信息或危害系统。威胁信息完整性和有效性的攻击就是主动攻击。主动攻击通常易于探测但却难于防范，因为攻击者可以通过多种方法发起攻击。常见的主动攻击包括：篡改、伪装、重放、拒绝服务攻击。答案选择 B 选项。

物理攻击是指攻击者可以直接接触到信息与网络系统的硬件、软件和周边环境设备。通过对硬件设备、网络线路、电源、空调等的破坏，使系统无法正常工作，甚至导致程序和数据无法恢复。

分发攻击是指在软件与硬件开发出来之后到安装之前的这段时间，或当它从一个地方传输到另一个地方时，攻击者恶意修改软/硬件，这种攻击可能给一个产品引入后门程序等恶意代码，以便日后在未获授权的情况下访问信息或系统。

4.

【问题 1】

- (1) (e) 应用层
- (2) (d) 合约层
- (3) (j) 智能合约
- (4) (c) 激励层
- (5) (m) 分配机制
- (6) (b) 共识层
- (7) (f) 网络层
- (8) (i) PoW
- (9) (l) 传播机制
- (10) (k) PBFT
- (11) (a) 数据层
- (12) (n) P2P 网络

【问题 2】

PBFT 通过三个阶段（预准备、准备、提交）实现节点间多轮投票，当 2/3 以上节点达成一致时确认区块。对比 PoW：

- 性能：PBFT 秒级确认，PoW 需分钟级别；
- 能耗：PBFT 无算力竞争，PoW 高能耗；
- 场景：PBFT 适合联盟链，PoW 适合公链。

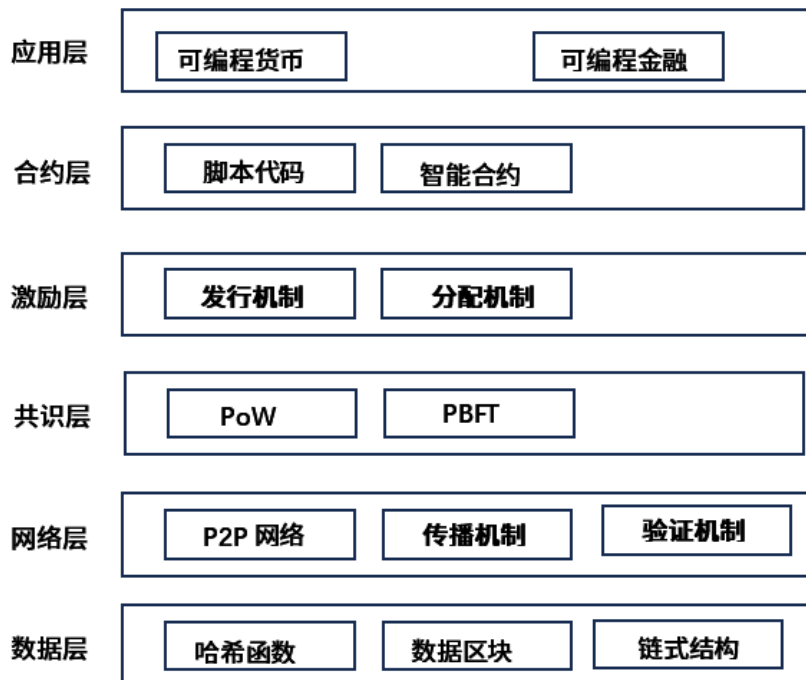
【问题 3】

用户向 CA 申请数字证书验证身份；支付时使用零知识证明向验证节点证明证书有效性，无需透露具体信息。

【试题解析】

【问题 1】

区块链是一种块链式存储、不可篡改、安全可信的去中心化分布式账本，它结合了分布式存储、点对点传输、共识机制、密码学等技术，通过不断增长的数据块链记录交易和信息，确保数据的安全和透明性。下图是区块链基础架构的六层模型。



【问题 2】

PBFT 通过领导者节点发起提案，其余节点验证后广播投票，适用于低延迟场景；而 PoW 依赖算力竞争，更强调去中心化但效率低下。PBFT 通过三个阶段（预准备、准备、提交）实现节点间多轮投票，当 2/3 以上节点达成一致时确认区块。对比 PoW：

- 性能：PBFT 秒级确认，PoW 需分钟级别，一般是 10 分钟以上；
- 能耗：PBFT 无算力竞争，PoW 高能耗；
- 场景：PBFT 适合联盟链，PoW 适合公链。

【问题 3】

用户向 CA 申请数字证书验证身份；支付时使用零知识证明（如 zk-SNARKs）向验证节点证明证书有效性，无需透露具体信息。所以，零知识证明解决了 KYC 与隐私的矛盾，数字证书提供权威背书，二者结合符合 GDPR 等法规要求。